

3ITCSC APPLIED SECURITY PROJECT

AUTHN/AUTHZ beveiligd met MFA breken

Advanced Identity & Authentication Attack project

Opleiding	Bachelor Cybersecurity & Cloud
Jaar	3e jaar
Groepsgrootte	+/-4 studenten per groep
Duur	12 weken

1. Projectbeschrijving & Context

1.1 Achtergrond

Moderne bedrijfsomgevingen steunen bijna volledig op identiteitsbeheer als primaire beveiligingslaag. Na de introductie van het Zero-Trust model — waar jullie vorig jaar via SASE al kennis mee maakten — wordt "Identity is the new perimeter" steeds meer realiteit. Microsoft Entra ID (voorheen Azure AD), Google Workspace en AWS IAM vormen de ruggengraat van authenticatie en autorisatie in cloud-native omgevingen.

Aanvallers hebben dit begrepen. Groepen zoals Lapsus\$, Midnight Blizzard en Scattered Spider voeren hun meest impactvolle aanvallen uit via identity-based attacks: het stelen van tokens, het omzeilen van MFA en het misbruiken van verkeerd geconfigureerde OAuth-applicaties. Zelfs wanneer MFA is ingeschakeld, bieden legitieme enterprise authenticatieprotocollen aanvalsvectoren die weinig bekendheid genieten.

In dit project onderzoeken jullie het volledige aanvalsoppervlak van moderne authenticatieprotocollen en MFA-methoden. Het doel is niet enkel aanvallen uitvoeren, maar ze ook zelf te onderzoeken, uit te voeren, te documenteren en te evalueren — inclusief de vraag of ze bestand zijn tegen toekomstige quantumcomputers. Jullie bepalen zelf de aanvalsvectoren, tooling en aanpak; dit document beschrijft enkel de opdracht, de op te leveren resultaten en de beoordelingscriteria.

1.2 Opdracht, Doelstellingen & Scope

Na afloop van dit project kunnen studenten:

- De zwakheden van authenticatieprotocollen (cert-based, SAML, OAuth 2.0, OIDC) technisch beargumenteren en aantonen via een zelf ontwikkelde proof-of-concept.
- Token-gebaseerde aanvallen uitvoeren: diefstal van PRT, refresh- en access-tokens, en deze tokens opnieuw inzetten om een sessie of connectie op te zetten.
- Per MFA-methode een gerichte aanval opzetten en aantonen welke aanvallen geblokkeerd worden en welke nog slagen.
- Onderbouwd motiveren waarom bepaalde aanvallen wel of niet lukken in een specifieke configuratie.
- De quantumbestendigheid van elke authenticatiemethode beoordelen en koppelen aan de post-quantum roadmap.
- Een security scorekaart met motivatie opstellen voor elke combinatie van authenticatieprotocol en MFA-methode.

De opdracht omvat de volgende onderdelen

Authenticatieprotocollen — onderzoek zwakheden en verkeerde implementaties van:

- Certificate-based authentication
- SAML
- OAuth 2.0
- OpenID Connect (OIDC)

Token-diefstal en -misbruik:

- Steel de MFA-tokens: Primary Refresh Token (PRT), refresh-token en access-token.
- Zet de gestolen tokens vervolgens in om een werkende connectie of sessie op te zetten.

MFA-methoden — werk per methode een workaround uit en demonstreer deze:

- MFA met SMS
- MFA met OTP software
- MFA met OTP hardware
- MFA met Microsoft Authenticator
- Passwordless MFA
- Passkey met Windows Hello for Business (WHFB)
- Passkey met Microsoft Authenticator — onderzoek daarbij de proximity check en domain binding
- Passkey met hardware dongle — onderzoek de proximity check (is relaying mogelijk?) en domain binding
- Passkey met Tenbeo

Onderzoeksvraag (WHFB): *bevestig of weerleg dat een pincode van 4 karakters veiliger is dan een wachtwoord van 12 karakters in Entra ID. Onderbouw met eigen testresultaten.*

Verdediging tegen tokendiefstal:

- Beschrijf en test token binding en andere methoden om diefstal van tokens tegen te gaan.
- Toon per MFA-methode aan welke aanvallen door deze verdedigingen geblokkeerd worden en welke nog slagen.

Aanpak, tooling en demo:

- Gebruik evil-proxy tooling of andere tools om de aanvallen uit te testen.
- Toon elke aanval aan met een demo. Als een aanval praktisch niet lukt, documenteer dan waar je tegenaan loopt en wat theoretisch toch mogelijk zou moeten zijn.

Quantumbestendigheid:

- Noteer per methode of ze quantum resistant is. Passkeys die vandaag veilig zijn maar over enkele jaren steunen op asymmetrische encryptie die door Q-day deprecated raakt, verdienen daarvoor een minpunt.

Security score:

- Geef per combinatie van authenticatie- en MFA-methode een score op 10.
- De motivatie moet duidelijk en volledig uitgewerkt zijn — niet enkel op basis van de hack-demo's, maar ook op basis van binding, phishing-resistance, tokenrisico en quantumbestendigheid.

2. Deliverables

2.1 Technisch Eindrapport

Het eindrapport bevat per onderdeel (protocollen, tokens, MFA-methoden, verdedigingen):

- Theoretische onderbouwing van de aanval of kwetsbaarheid.
- Technische uitwerking van de aanval (tooling, configuratie, commando's).
- Demobeschrijving en bevindingen, inclusief wat mislukt is en waarom.
- Quantumbestendigheidsanalyse per methode.
- Security score met uitgebreide motivatie (minimaal één pagina per MFA-methode).

2.2 Demo's

Per MFA-methode is een aantoonbare demo vereist, bij voorkeur als schermopname (video) OF als live-demo. Minimale inhoud per demo:

- Omschrijving van de startcondities (welke policies actief, welke tools gebruikt).
- Uitvoering van de aanval stap voor stap.
- Resultaat: gelukt of mislukt, met motivatie.
- Als praktische uitvoering niet lukt: waar loop je technisch tegenaan en wat zou theoretisch toch moeten werken?

2.3 Security Scorekaart

Een overzichtstabel met, per combinatie van authenticatie- en MFA-methode: de primaire bevinding, of de aanval geblokkeerd wordt, de quantumbestendigheid en een score op 10 met verwijzing naar de onderbouwing in het rapport.

2.4 Lab-documentatie

- Opbouw van de volledige labomgeving (diagram + stapsgewijze installatie).
- Configuratie van de Entra ID tenant (Conditional Access policies, MFA-registraties).
- Configuratie van de gebruikte tooling en proxy-opstelling.

2.5 Presentatie & Live Demo

Een technische presentatie van maximaal 30 minuten + 15 minuten Q&A. Elk groepslid presenteert minimaal één onderdeel. Verwacht wordt dat alle groepsleden de volledige scope begrijpen.

Evaluatiecriteria

- Analyse van de probleemstelling
- Kwaliteit van het onderzoek naar oplossingen
- Kwaliteit van de verschillende deliverables
- Werking van de Proof of Concept
- Praktische bruikbaarheid van het adviesrapport.